AI Act Compliance: Review of AURA Subsystem 05

Mission: 05 | Dual-Path GraphRAG, Hybrid Search & The Google NotebookLM Grounding Lab

Squadron: Koller | **Officers:** [Antoun Al Salameh 5019770] [Ragni Chawala 5012421]

Waypoint: Crab Pulsar Remnant / Messier 1 (SEC-05-M01) | **Subsystem:** 05 - Dual-Path Associative Memory Core

Course: Conversational AI - Winter Semester 2026/27 | **Station(s):** AI Security Officer (Regulatory Compliance & Security)

Scope: Dual-Path Associative Memory Core (HNSW + BM25 + RRF retrieval, IPI detector, RAG Triad scorer, provenance log) and the NotebookLM audit | **Legal basis:** Regulation (EU) 2024/1689 (AI Act) | **Review date:** 2026-11-08

1. Executive Summary

Question	Answer
Is Subsystem 05 a prohibited practice (Art. 5)?	No. Retrieval and grounding use no subliminal, manipulative or exploitative techniques and no social scoring.
Is it a high-risk AI system (Art. 6, Annex III)?	No. A course-setting retrieval prototype over technical documents is not an Annex III use case.
Do transparency duties apply (Art. 50)?	Yes, if deployed to users: it answers questions in natural language. Art. 50(1) needs an AI disclosure.
Does the IPI filter or the refusal behaviour create legal risk?	No. They reduce risk; the residual risk is technical (bypass), not regulatory.

Verdict: Subsystem 05 is compliant as an educational prototype once the Art. 50(1) disclosure is added. The main residual hazards are operational and data-protection related: indirect prompt injection that a heuristic filter can miss, confabulated answers, and personal data in the provenance log.

This review is a course exercise, not legal advice. Confirm the current application dates and any amendments to the AI Act before a real deployment.

2. Risk Classification Analysis

Prohibited practices (Art. 5) are not triggered. The system retrieves and quotes source text; it does not alter user behaviour covertly, exploit vulnerabilities, or categorise people.

High-risk (Annex III) is not triggered. No biometrics, critical infrastructure, education scoring, employment, essential services or law-enforcement data are processed. If the same architecture were later used to decide on people (for example grading students), the classification would have to be redone.

Limited risk (Art. 50) applies. The system interacts directly with natural persons through text. Whether the core is deterministic or an LLM does not change the user-facing duty to say it is an AI system, unless that is obvious from context.

General-purpose AI model duties (Art. 53) rest with the provider of the underlying model. For NotebookLM that is Google; for any LLM plugged into our generator slot it is that model's provider. The squadron is a downstream deployer.

3. Article 50 Transparency Checklist

Requirement	Status	Evidence / Remediation
Users told they are interacting with AI (Art. 50(1))	Gap	Add to the first reply of every session: "You are talking to an automated retrieval system (AI)."
Synthetic text/audio marked machine-readably (Art. 50(2))	N/A now	The current generator is extractive (copies source sentences). If an LLM is added, the provider must mark output; keep the provenance log as an internal record.
Emotion recognition / biometric categorisation (Art. 50(3))	Pass	Not used.
Deep fakes / AI-generated text published to inform the public (Art. 50(4))	Pass	Nothing is published. If the Audio Overview excerpt is shared, label it as AI-generated audio from NotebookLM.

4. Security, Data and Hazard Checks

4.1 Indirect prompt injection

Retrieved chunks are untrusted input. The IPI detector blocked the poisoned demo chunk (override instruction plus markdown-image exfiltration URL) in testing, and passing chunks are sanitised and fenced as quoted data. Residual risk: regex and embedding heuristics can be bypassed by encoding, other languages, or novel phrasing. Treat the detector as one layer, add output filtering and least-privilege tool access, and log every blocked chunk for review.

4.2 Hallucination and false assurance

Refusal on absent facts worked in the demo. However the RAG Triad scorer is a token/embedding proxy; it reported context relevance 1.0 for an unanswerable query. Do not present these scores as validated safety metrics. Likewise a NotebookLM citation badge is not proof of entailment, which is why the audit checks each cited span.

4.3 Personal data and the provenance log

provenance_log.jsonl stores each user query verbatim. Queries can contain personal data, so GDPR applies in a real deployment: collect only what is needed, set a retention period, restrict access, and redact identifiers. Art. 12 record-keeping is mandatory only for high-risk systems, but the log is good practice here.

4.4 Third-party tool and source material

Uploading the papers and the course archive extract to NotebookLM sends them to Google. Check the course rules and the licences of Documents A, B and C before upload, and do not upload anything containing personal or confidential data.

5. Actions Before Final Deployment

- 1. Add the AI disclosure notice to the first reply of every session (Art. 50(1)).
- 2. Log blocked chunks, review them, and extend the IPI detector (multilingual and encoded payloads); do not rely on it as the only defence.
- 3. Add retention limits and identifier redaction to the provenance log (GDPR).
- 4. Label any shared Audio Overview excerpt as AI-generated, and cite NotebookLM as the source.
- 5. Replace the proxy triad metrics with NLI or LLM-judge scoring and validate thresholds on labelled data before using scores in any decision.
- 6. Re-run this classification if the use case moves beyond a course prototype (for example evaluating or ranking people).